

**ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
« НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО»**

Олимпиадный кейс

«Концепция исследования в области кибербезопасности»

Пример оформленного решения (эталон для понимания ожидаемого уровня)

Тема исследования: Снижение ложных срабатываний при выявлении «low-and-slow» атак в SOC-логах за счёт временной агрегации и интерпретируемых признаков

Ф.И.О. автора:

Иванов Иван Иванович

Санкт-Петербург, 2026

Введение. Постановка проблемы и актуальность

SOC-подразделения опираются на корреляционные правила и статистические детекторы для выявления атак по журналам аутентификации, сетевой телеметрии и событиям хостов. Практическая проблема состоит в том, что многие целевые кампании реализуются в виде «low-and-slow» сценариев: действия распределены во времени, интенсивность низкая, и атакующее поведение маскируется под фоновые операции. Классические правила (пороги, сигнатуры) часто дают высокую долю пропусков (FN), а попытка «закрутить гайки» обычно приводит к росту ложных срабатываний (FP) и перегрузке аналитиков.

Научная и практическая актуальность темы подтверждается тем, что современные работы по анализу логов и обнаружению аномалий уделяют большое внимание вопросу формирования последовательностей/окон наблюдений и влиянию «окна» на качество детекции, а также проблеме интерпретируемости и доверия к моделям (особенно в высокорисковых задачах).

1. Цель, задачи и гипотеза

Цель исследования: повысить полноту обнаружения при контролируемом уровне ложных срабатываний за счет разработки и исследования подхода к выявлению low-and-slow атак по SOC-логам,

Научная задача: оптимизировать Recall–FP при детекции слабовыраженных атакующих паттернов за счет выбора стратегии временной агрегации и набора интерпретируемых поведенческих признаков.

Задачи исследования:

- 1) Выполнить анализ существующих подходов к log-based / security anomaly detection и проблематики окон/последовательностей.
- 2) Сформировать модель данных и схему агрегации событий (окна по времени + ограничение по числу событий).
- 3) Разработать набор временных поведенческих признаков (частоты, энтропии, переходы состояний, «burstiness» и др.).

4) Сравнить базовую детекцию (правила/простые пороги) и предложенный подход на сопоставимых данных.

5) Оценить интерпретируемость: представить объяснения (какие признаки «вытянули» алерт) и провести анализ ошибок.

Гипотеза. Комбинация (i) гибридного формирования окон наблюдения (ограничение по времени и по числу событий) и (ii) интерпретируемых временных признаков поведения субъектов (пользователь/хост) позволит повысить Recall при выявлении low-and-slow атак по сравнению с базовыми правилами, не приводя к непропорциональному росту FP-rate.

2. Подход и методология (в кратком виде)

Предлагается перейти от анализа отдельных событий к анализу «поведенческих профилей» субъектов. Для каждого субъекта строится последовательность событий; далее формируются окна наблюдения гибридным способом: окно ограничено одновременно длительностью T и числом событий L (чтобы не получать ни «пустые», ни «гигантские» последовательности). Для каждого окна вычисляются признаки: частоты типов событий, доли неуспешных попыток, распределения по времени суток, энтропия источников, статистики межсобытийных интервалов, и т.п.

Детекция выполняется двумя параллельными контурами: (1) baseline-правила (простые, объяснимые), (2) легковесная модель аномалий (например, Isolation Forest или кластеризация) по признакам окна. Результаты сводятся в единый список алертов с объяснением: какие признаки и какие правила сработали.

3. Ожидаемые результаты и значимость

Ожидаемые результаты: (i) описанная и воспроизводимая схема агрегации SOC-событий (T, L -окна), (ii) набор интерпретируемых признаков для выявления низкоинтенсивных паттернов, (iii) результаты сравнительных экспериментов и анализ компромисса Recall–FP, (iv) рекомендации по внедрению в SOC-процессы (triage и приоритизация алертов).

Практическая применимость: SOC/IR-команды в организациях с централизованным сбором логов (SIEM/SOAR), а также разработчики детекторов. Научная значимость: уточнение роли временной структуры логов и окна наблюдения, а также подход к интерпретируемому anomaly detection в задачах безопасности.

Заключение

Было проведено мини-исследование, в рамках которого были получены следующие результаты:...

Список источников

- Landauer M. et al. Deep learning for anomaly detection in log data: A survey. 2023.
- Zeufack V. et al. An unsupervised anomaly detection framework for real-time log monitoring. 2021.
- Sedláček O. et al. Anomaly Detection in Log Data: A Comparative Study. 2025.
- Li R. et al. Interpreting Unsupervised Anomaly Detection in Security Applications. NeurIPS 2023.
- Bagui S. et al. Detecting Reconnaissance and Discovery Tactics from Zeek Logs (dataset paper). 2022.
- MITRE ATT&CK: Credential Access (TA0006) и связанные техники. Актуальная версия на сайте MITRE.

A1. Схема предметной области и потоков данных

Ниже приведена текстовая схема (в работе участника может быть диаграмма).

- Источники событий: Windows Event Log / Linux auth, сетевые журналы (Zeek/Netflow), VPN/RDP, SIEM-алерты.
- ETL: нормализация → дедупликация → обогащение (контекст пользователя/хоста/группы).
- Агрегация: построение окон (Т секунд и/или L строк) по субъекту.
- Feature Engineering: вычисление временных и поведенческих признаков.
- Детекция: baseline правила + модель аномалий (unsupervised).
- Выход: алерты с объяснениями + отчёт об ошибках (FP/FN).

A2. Описание структур данных

Таблица 1 — Минимальная структура события (лог-запись).

Поле	Тип	Пример	Назначение
timestamp	datetime	2026-01-30 12:34:56	время события
subject_id	string	user:ivanov / host:pc-12	субъект агрегации
event_type	categorical	AUTH_FAIL / PROC_START	тип события
src	string	10.1.2.3 / vpn-gw	источник/контекст

Таблица 2 — Структура агрегированного окна наблюдения W.

Компонент	Описание	Пример	Комментарий
W.meta	границы окна, субъект	T=30m, L=200, subject=user:ivanov	гибридное окно
W.counts	частоты event_type	{AUTH_FAIL: 12, AUTH_OK: 1}	простые признаки
W.timing	статистики интервалов	meanΔt=140s, p95Δt=600s	low-and-slow маркеры
W.context	контекст	role=admin, dept=IT	обогащение

А3. Формализация задачи и метрики

Пусть G — множество истинных атакующих эпизодов (ground truth), A — множество сгенерированных системой алертов. Основные метрики: $\text{Recall} = |A \cap G| / |G|$ и $\text{FP-rate} = |A \setminus G| / |A|$. Цель — увеличить Recall при ограничении роста FP-rate. Дополнительно фиксируется нагрузка на аналитика: среднее число алертов в сутки и доля «высокоприоритетных».

А4. План экспериментов

1. E1. Подготовка данных: выбор источника логов (например, открытые Zeek-логи/синтетические логи), нормализация.
2. E2. Формирование ground truth: внедрение/симуляция low-and-slow сценариев (например, brute force с паузами, разведка, постепенное повышение привилегий).
3. E3. Baseline: набор простых правил (пороги по неуспешным входам, редкие event_type, необычные часы активности).
4. E4. Предлагаемый подход: окна (T,L) + признаки + модель аномалий.
5. E5. Сравнение: Recall, FP-rate, алерты/сутки; разбор FP и FN на примерах.
6. E6. Интерпретируемость: для каждого алерта — топ-3 признака/правило; качественная оценка удобства triage.

A5. Таймлайн на 2 года (укрупнённо)

Таблица 3 — План-график работ (пример диаграммы Ганта в текстовом виде).

Период	Работы	Результат
Кв. 1–2	Литобзор, постановка, модель данных, прототип ETL	Обзор + спецификация данных
Кв. 3–4	Окна (T,L), признаки, baseline детекторы	Набор признаков + baseline
Кв. 5–6	Эксперименты, настройка, анализ FP/FN	Сравнительная оценка
Кв. 7–8	Интерпретируемость, рекомендации, публикация	Отчёт + статья/препринт

А6. Датасеты и источники данных

Планируется использовать: (1) открытые наборы сетевых логов (например, Zeek-логи на основе Security Onion), (2) синтетические сценарии атак, внедряемые в поток событий. При отсутствии готового ground truth допускается создание размеченной выборки экспертами на подмножестве данных.

A7. Ресурсное обеспечение

Вычислительные ресурсы: CPU-сервер/рабочая станция; GPU не обязателен.
Человеческие ресурсы: 1 исследователь + 1 эксперт SOC на этапе разметки/валидации. Временные ресурсы: итерации экспериментов 1–2 недели каждая, с накоплением результатов.